

PUBLIC PROFESSIONAL BRIEF

NorthGrid Energy Security Program Assessment

A public professional summary of a six-phase cybersecurity risk assessment for a fictional Ontario critical infrastructure operator.

Prepared by	Bernard Boakye Appiah
Scenario organization	NorthGrid Energy - fictional Ontario critical infrastructure operator
Document type	Full program assessment
Public disclosure	All content is sanitized and based on a fictional security assessment scenario.
Date	July 2026

Selected assessment metrics

6 Phases	Cyber / Physical / Supply Chain Domains	12 months Roadmap
-------------	--	----------------------

Public disclosure note: NorthGrid Energy is a fictional scenario used to demonstrate professional cybersecurity assessment, governance, and risk communication skills. The content is sanitized for public review and does not contain proprietary or private operational data.

OVERVIEW

Executive Summary

NorthGrid Energy was assessed as a fictional mid-size Ontario electrical utility with an operating control centre, remote substations, a mixed IT/OT environment, and several third-party service dependencies. The assessment was designed as an end-to-end security program review covering governance, threat surface mapping, identity and access management, resilience, vulnerability management, detection engineering, incident response, and security roadmap planning.

The starting posture showed common critical infrastructure weaknesses: flat IT/OT connectivity, incomplete MFA coverage, limited documented governance, persistent vendor VPN access, weak physical separation around operational areas, and no formal SBOM requirement in vendor contracts. The final output was a practical improvement program that connects risk to controls, assigns priorities, and maps progress to NIST CSF 2.0 outcomes.

6 integrated phases Assessment phases	Cyber + Physical + Supply Chain Security domains	NIST CSF 2.0 Framework baseline
88.88% CIS L1 OpenSCAP baseline	2,393 components SBOM inventory	119 CVEs Vulnerability findings
137 tests / 21 warnings Docker Bench	\$195,000 ALE Risk quantification	Tier 3 maturity Roadmap target

SCOPE

Scenario Scope and Security Context

NorthGrid Energy represents a public-facing portfolio case study for critical infrastructure security assessment. The fictional environment includes Microsoft 365, on-premises Active Directory, Fortinet perimeter firewalls, Cisco networking, GE Grid Solutions EMS on Windows Server 2016, a regional NOC, three remote substations, and third-party services such as HVAC/BMS support, managed SOC operations, and cloud backup.

Area	Public-view scope used in this assessment
Cyber domain	Remote access, Active Directory, Microsoft 365, firewall exposure, endpoint baselines, container security, logging, detection engineering.
Physical domain	NOC access control, visitor movement, CCTV gaps, OT cabinet room protection, badge access, CPTED principles.
Supply chain domain	Vendor VPN access, cloud backup dependency, SBOM requirements, managed SOC update risk, C-SCRM controls.
Governance domain	Risk appetite, policy ownership, incident response planning, vulnerability prioritization, maturity roadmap.

METHODOLOGY

Assessment Method

The project used a phased assessment method that allowed each phase to feed the next. Baseline findings from the threat surface and NIST CSF profile informed the IAM review; IAM and vendor findings informed the resilience assessment; resilience and SBOM findings informed vulnerability prioritization; and the final tabletop and roadmap converted findings into decisions and actions.

Phase	Focus	Professional deliverable
1	Threat surface and CSF profiling	Current-state CSF profile, cross-domain dependency map, Colonial Pipeline comparison.

Phase	Focus	Professional deliverable
2	Threat actor and supply chain intelligence	APT29/SolarWinds threat model, ATT&CK mapping, sector-relevant control gaps.
3	Identity and vendor access	Keycloak IAM model, role design, physical-to-logical tier analysis, vendor JIT/JEA recommendations.
4	Resilience and baseline hardening	OpenSCAP results, CPTED review, DR supplier dependency matrix, staged rollout policy.
5	SBOM and detection engineering	Docker Bench findings, CycloneDX SBOM summary, Gripe vulnerability findings, Sigma detection logic.
6	Prioritization and governance roadmap	KEV/EPSS/CVSS remediation queue, ransomware tabletop decisions, ALE calculation, 12-month roadmap.

DETAILED RESULTS

Phase-by-Phase Public Results

Each phase produced a specific professional security deliverable. The purpose of this section is to show the work as an integrated assessment rather than as isolated classroom exercises.

Phase 1 - Threat Surface and CSF Profiling

The first phase established the baseline risk picture. NorthGrid was profiled across cyber, physical, and supply chain domains, then mapped to NIST CSF 2.0 functions. This showed that governance, asset visibility, remote access, and segmentation were not mature enough for a critical infrastructure operator. The Colonial Pipeline comparison was used to validate why weak VPN control and poor IT/OT segmentation can create real operational consequences.

Phase 2 - Threat Actor and Supply Chain Intelligence

The second phase connected NorthGrid exposure to realistic adversary behavior. APT29 and SolarWinds were used to show how trusted software channels, domain credentials, and remote services can bypass traditional perimeter thinking. This phase strengthened the assessment by showing that vendor trust, update integrity, DNS monitoring, and credential controls belong in the same risk conversation.

Phase 3 - Identity and Vendor Access

The third phase converted identity concepts into a working access model. Keycloak was used to represent roles for OT operators, IT administrators, help desk users, and HVAC vendors. The most important result was not the tool itself, but the access logic: vendors should receive only the access needed, only for the approved time window, and only with strong authentication and monitoring.

Phase 4 - Resilience and Baseline Hardening

The fourth phase measured endpoint baseline posture and site resilience. OpenSCAP results showed strong overall compliance but important weaknesses around password quality, account lockout, log permissions, and privileged access restrictions. The physical review showed that the NOC and OT cabinet room needed controls that match their operational importance. The disaster recovery supplier review highlighted the cloud backup vendor and managed SOC provider as critical dependencies.

Phase 5 - SBOM and Detection Engineering

The fifth phase added software supply chain visibility and detection engineering. The SBOM and Gripe scan demonstrated that a software component inventory can reveal vulnerabilities hidden below the application name. Docker Bench warnings were converted into container hardening priorities. Sigma-style detections were written for MFA fatigue and suspicious OT scheduled task activity, with attention to the log sources needed for the rules to actually work.

Phase 6 - Prioritization, IR, and Governance Roadmap

The final phase converted findings into decisions. Vulnerabilities were prioritized using KEV, EPSS, CVSS, asset confirmation, and reachability. A ransomware tabletop tested containment, evidence preservation, and no-ransom decision logic. The governance roadmap then organized the next 12 months of improvement around ownership, asset inventory, MFA, PAM, segmentation, OT-safe monitoring, and tested recovery.

Phase	Evidence-backed result	Business security value
1	CSF current-state profile and cross-domain dependency map.	Creates a baseline for risk ownership and maturity planning.
2	APT29/SolarWinds TTP mapping and C-SCRM analysis.	Shows how adversary behavior connects to vendor trust and identity risk.
3	Keycloak RBAC model and vendor privilege audit.	Demonstrates least privilege, JIT access, and physical-logical control alignment.
4	OpenSCAP scan, CPTED review, and DR dependency matrix.	Connects technical hardening with site resilience and supplier continuity.
5	Docker Bench review, SBOM scan, KEV cross-reference, Sigma rules.	Turns tool output into actionable hardening, vulnerability, and detection work.
6	Risk-prioritized remediation queue, ALE calculation, IR tabletop, 12-month roadmap.	Converts assessment findings into leadership-ready decisions and control sequencing.

RESULTS

Integrated Findings

The strongest finding across the project was that NorthGrid's risk was not isolated to one layer. Identity weaknesses, flat network design, physical access gaps, and vendor dependencies created combined attack paths. The assessment therefore avoided treating cybersecurity as a purely technical checklist and instead connected cyber, physical, and supply chain exposure to operational resilience.

Finding theme	Evidence summary	Risk meaning
Remote access and IAM	MFA existed for Microsoft 365 but not VPN; contractor access was persistent and unreviewed.	A stolen or misused credential could provide a remote entry path into an environment with weak internal segmentation.
IT/OT segmentation	OT and corporate IT were connected through a single firewall without a mature industrial DMZ model.	An IT compromise could become an OT availability problem if EMS-supporting paths remain reachable.
Physical access alignment	NOC and OT cabinet room lacked dedicated controls that matched operational sensitivity.	Physical proximity to operational systems could amplify cyber risk through USB, workstation, or network-port misuse.
Software supply chain visibility	No SBOM requirements were present in vendor contracts; Syft/Grype testing showed many components below the main application layer.	Without component visibility, embedded vulnerabilities can remain unknown until exploitation or vendor disclosure.
Detection and response	Sigma logic was created for MFA fatigue and OT scheduled-task behavior; tabletop revealed need for clearer IR escalation.	Detection is only useful when logs are collected, alerts are triaged, and response authority is defined.

RISK DECISIONS

Quantitative and Prioritization Results

Risk item	Method	Public-view result
EternalBlue / SMBv1 exposure	Annualized Loss Expectancy	SLE \$650,000 x ARO 0.30 = \$195,000/year. The low-cost SMBv1 verification control was financially justified.
Palo Alto GlobalProtect exposure	KEV + EPSS + asset reachability	CVE-2024-3400 was treated as P1 because the asset was confirmed, externally reachable, KEV-listed, and high EPSS.
Log4Shell in EMS dependencies	SBOM uncertainty + OT safety	CVE-2021-44228 was treated as P1 pending vendor/SBOM verification because EMS component visibility was incomplete.

Risk item	Method	Public-view result
Flat IT/OT network	ALE-based control decision	Industrial DMZ investment was justified against high-impact OT disruption scenarios.

ROADMAP

12-Month Roadmap Summary

The roadmap prioritizes controls that create ownership first, then visibility, then protective controls, then monitoring and recovery maturity. This order prevents the project from becoming a list of isolated tools without governance.

Timeframe	Priority work	Expected maturity gain
Month 1	Appoint vCISO/security owner, approve security policy, implement help desk verification.	Governance ownership established; social engineering path reduced.
Months 2-3	Create OT asset inventory, remove shared admin use, enable MFA for VPN and privileged access, draft NERC CIP-style IR process.	IDENTIFY and PROTECT maturity moves from ad hoc toward repeatable.
Months 4-6	Deploy industrial DMZ, implement KEV/EPSS/asset-criticality vulnerability process.	Flat-network risk reduced; vulnerability work becomes risk-driven.
Months 7-9	Add OT-safe monitoring for EMS/historian traffic and harden EMS access paths.	DETECT capability expands beyond endpoint and Microsoft 365 telemetry.
Months 10-12	Run ransomware tabletop and backup restoration test with RTO/RPO measurement.	RESPOND and RECOVER capabilities become measurable and tested.

RECOMMENDATIONS

Program Recommendations

- 1 Enforce phishing-resistant MFA for VPN, privileged users, and vendor remote access, with break-glass procedures for emergency operations.
- 2 Implement an industrial DMZ and restrict direct IT-to-OT paths, including EMS egress controls and controlled vendor support access.
- 3 Deploy privileged access management for named administrator accounts, remove shared admin credentials, and apply just-in-time vendor access.
- 4 Mandate SBOMs and vendor attestation for critical OT/IT software, then prioritize vulnerabilities using KEV, EPSS, CVSS, asset ownership, and reachability.
- 5 Improve physical security for the NOC and OT cabinet room with dedicated badge access, CCTV coverage, anti-passback, and visitor escort enforcement.
- 6 Centralize the logs needed for Sigma detections, especially Windows Security Event ID 4698 and Microsoft Entra ID sign-in logs.
- 7 Exercise ransomware response and backup recovery quarterly so leadership decisions are tested before a real incident.

SKILLS

Professional Skills Demonstrated

Skill area	Demonstrated through
GRC and risk assessment	NIST CSF 2.0 profiling, maturity scoring, ALE calculations, roadmap planning.

Skill area	Demonstrated through
Critical infrastructure security	IT/OT segmentation analysis, EMS risk handling, NOC physical control assessment.
Identity security	Keycloak RBAC model, MFA analysis, PAM/JIT/JEA vendor access recommendations.
Vulnerability management	SBOM generation, Gype vulnerability scan, KEV/EPSS/CVSS prioritization.
Detection engineering	Sigma rules for OT scheduled tasks and MFA push fatigue, false positive review, logging requirements.
Incident response	Ransomware tabletop decisions, containment, evidence preservation, recovery sequencing.